

```
## 룰 추가
cd /etc/nginx/modsec
vi my_rules.conf

# --- My Custom Rules (ID Range: 1000001+) ---

# ID 1000001: SQL 인젝션
SecRule ARGS "@rx (?i)(union|select|insert|update|delete|drop|where|or\s+1\s*=\s*1)" \
    "phase:2,id:1000001,deny,log,status:403,msg:'[custom] SQL Injection Detected'"

# ID 1000002: OS 커맨드 주입
SecRule ARGS "@rx (?i)(/etc/passwd|/bin/sh|/bin/bash|cmd\.exe|powershell|cat\s+|ls\s+)" \
    "phase:2,id:1000002,deny,log,status:403,msg:'[custom] OS Command Injection Attempt'"

# ID 1000003: 브루트 포스 (initcol)
SecAction "phase:1,id:1000003,nolog,pass,initcol:ip=%{REMOTE_ADDR}"
SecRule REQUEST_FILENAME "@contains /login" "phase:2,id:1000004,chain,deny,status:403,log"
    SecRule ip:LOGIN_COUNT "@gt 10"

# ID 1000005: 로그인 카운트 증가
SecRule REQUEST_FILENAME "@contains /login" "phase:5,id:1000005,nolog,pass,setvar:ip.LOGIN_COUNT+=1"

# ID 1000006: DDoS 방어
SecAction "phase:1,id:1000006,nolog,pass,initcol:ip=%{REMOTE_ADDR}"
SecRule ip:REQUEST_RATE "@gt 100" "phase:1,id:1000007,deny,status:429,log,msg:'[custom] DDoS Attack'"
SecAction "phase:5,id:1000008,nolog,pass,setvar:ip.REQUEST_RATE+=1,expirevar:ip.REQUEST_RATE=0"

# ID 1000009: 경로 이탈
SecRule ARGS|REQUEST_FILENAME "@rx \\.\/" \
    "phase:2,id:1000009,deny,log,status:403,msg:'[custom] Directory Traversal Attack'"
# ARGS(파라미터)와 REQUEST_URI(경로 전체)를 모두 검사
SecRule ARGS|REQUEST_URI "test" "phase:2,id:1000011,deny,status:403,msg:'[custom] Custom Rule'"
```

```
vi main.conf
Include /etc/nginx/modsec/my_rules.conf # 추가
```

```
Include /etc/nginx/modsec/modsecurity.conf
Include /etc/nginx/modsec/my_rules.conf
Include /etc/nginx/modsec/crs-setup.conf
Include /etc/nginx/modsec/coreruleset/rules/*.conf
```

순서 중요함.

커스텀 룰즈인 my_rules.conf가 crs_setup.conf 보다 위에 있어야 crs 룰즈 보다 우선할 수 있다.

```
# 문법 체크
nginx -t

# 로그 확인
tail /var/log/modsec_audit.log
```

1. SQL 인젝션 공격

서버IP/index.php?id=1%27%20OR%201=1--

192.168.0.21/index.php?id=1%27%20OR%201=1--

ER Blue-Server - Goog... 공부를 합시다! - G... tj2025_취약점분석...

403 Forbidden

nginx/1.20.1

```
ModSecurity: Access denied with code 403 (phase 2). Matched "Operator 'Rx' with parameter '(?)' against variable 'ARGS:id' (Value: '1' OR 1=1--') [file "/etc/nginx/modsec/my_rules.conf"] [line "4"] [id "1000001"] [rev "" ] [msg "[custom] SQL Injection Detected"] [data "" ] [severity "0"] [accuracy "0"] [hostname "192.168.0.21"] [ip "192.168.0.21"] [uri "/index.php?id=1%27%20OR%201=1--"] [unique_id "176991968761.361282"] [ref "o3,6o3,6v18,11"]
```

2. OS 인젝션 공격

서버IP/main?cmd=cat%20/etc/passwd

192.168.0.21/main?cmd=cat%20/etc/passwd

ER Blue-Server - Goog... 공부를 합시다! - G... tj2025_취약점분석...

403 Forbidden

nginx/1.20.1

```
ModSecurity: Access denied with code 403 (phase 2). Matched "Operator 'Rx' with parameter '(?)' against variable 'REQUEST_URI' (Value: '/test') [file "/etc/nginx/modsec/my_rules.conf"] [line "27"] [id "1000001"] [rev "" ] [msg "[custom] Custom Rule Test Success!"] [data "" ] [severity "0"] [accuracy "0"] [hostname "192.168.0.21"] [ip "192.168.0.21"] [uri "/test"] [unique_id "176991999083.980316"] [ref "o1,4v4,5"]
```

3. 특정 단어가 들어가면 차단하기

192.168.0.21/test

```
ModSecurity: Access denied with code 403 (phase 2). Matched "Operator 'Rx' with parameter 'test' against variable 'REQUEST_URI' (Value: '/test') [file "/etc/nginx/modsec/my_rules.conf"] [line "27"] [id "1000001"] [rev "" ] [msg "[custom] Custom Rule Test Success!"] [data "" ] [severity "0"] [accuracy "0"] [hostname "192.168.0.21"] [ip "192.168.0.21"] [uri "/test"] [unique_id "176991999083.980316"] [ref "o1,4v4,5"]
```

4. DDOS 공격

```
for /L %i in (1,1,110) do @curl -s -o /dev/null -w "%{http_code} " "http://서버IP/"
```

윈도우 CMD에서 실행함.

```
C:\Users\jstpt>for /L %i in (1,1,110) do @curl -s -o /dev/null -w "%{http_code}" "http://192.168.0.21/"
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
C:\Users\jstpt>
ModSecurity: Access denied with code 429 (phase 1). Matched "Operator 'Gt' with parameter '100' against variable 'IP:192.168.0.16:::REQUEST_RATE' (Value: '109' ) [file "/etc/nginx/modsec/my_rules.conf"] [line "28"] [id "1000007"] [rev ""] [msg "[custom] DDoS Attack Detected - Rate Limit Exceeded"] [data ""] [severity "0"] [ver ""] [match_type "0"] [host name "192.168.0.21"] [url "http://192.168.0.21/login"] [unique_id "176992031477.383987"] [ref ""]
```

5. 브루트포스 공격

```
for /L %i in (1,1,12) do @curl -s -o /dev/null -w "%{http_code}\n" "http://서버주소/login?username=admin&password=%i"
```

윈도우 CMD에서 실행함.

```
C:\Users\jstpt>for /L %i in (1,1,12) do @curl -s -o /dev/null -w "%{http_code}\n" "http://192.168.0.21/login"
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 404
7월 11 : 403
ModSecurity: Access denied with code 403 (phase 2). Matched "Operator 'Gt' with parameter '10' against variable 'IP:192.168.0.16:::LOGIN_COUNT' (Value: '11' ) [file "/etc/nginx/modsec/my_rules.conf"] [line "13"] [id "1000004"] [rev ""] [msg "[custom] Brute Force Attack Prevented"] [data ""] [severity "0"] [match_type "0"] [match_data ""] [severity "0"] [match_data ""] [match_data "192.168.0.21"] [url "http://192.168.0.21/login"] [unique_id "176992056693.445443"] [ref "o0,6v4,6"]
```